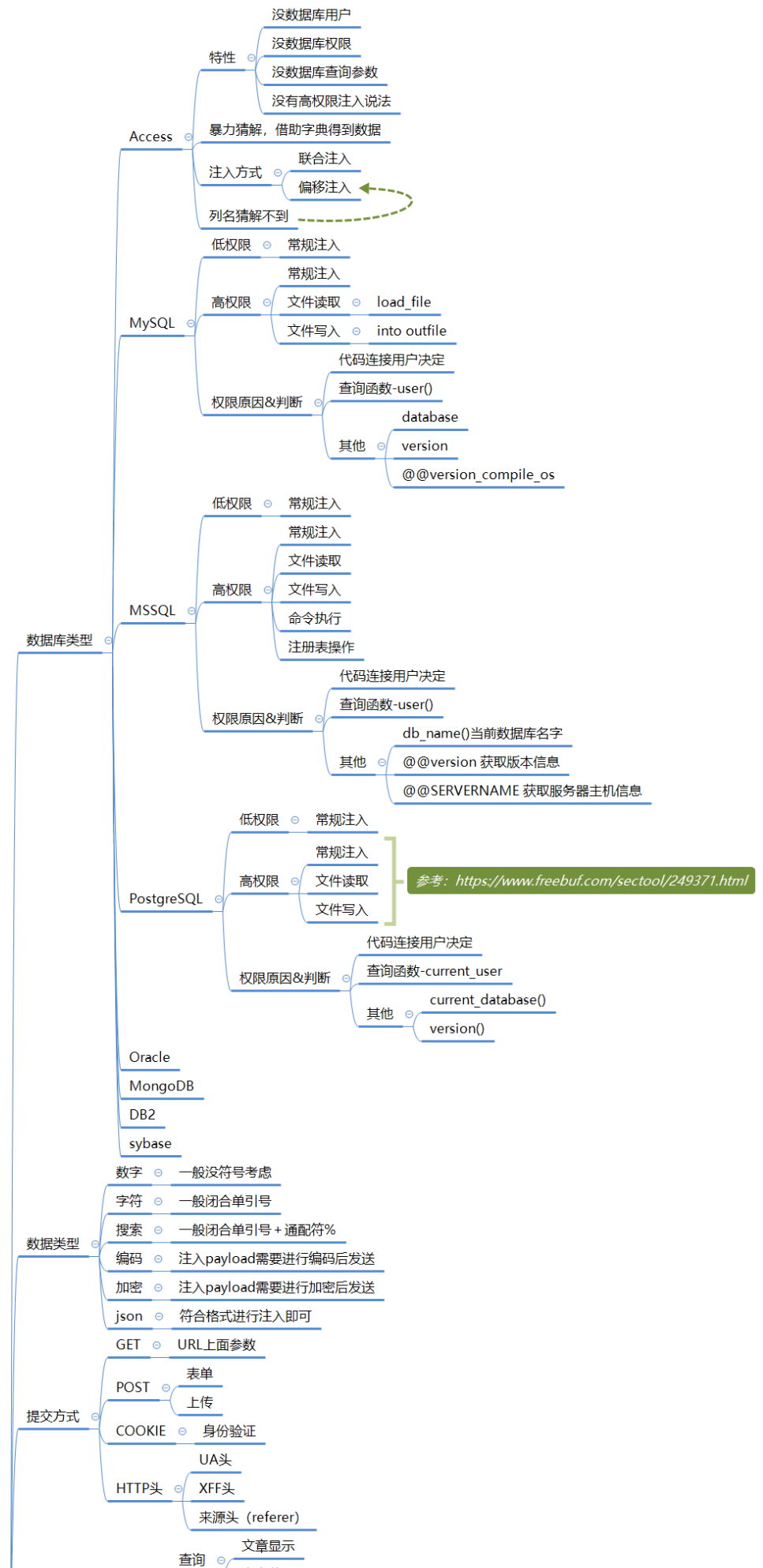


Day51 WEB攻防-前后台功能点&文件下载&文件读取&文件删除&目录遍历&目录穿越



SQL注入

查询方式

方式

删除

- 删除帖子
- 删除文章

插入

- 注册会员
- 添加新闻

更新

- 修改文章
- 修改密码

盲注

延时

- 利用时间判断，不需要任何条件

布尔

- 有数据库输出作为判断标准

报错

- 有数据库报错处理判断标准

测试

黑盒

- 根据应用功能

白盒

- 关键特征代码
- 根据应用功能

注入神器

SQLMAP

- <https://sqlmap.kvko.live/>

普通注入

爆库

- dbs

爆表

- tables -D "数据库名"

爆列

- columns -T "表名" -D "数据库名"

爆数据

- dump -C "列名" -T "表名" -D "数据库名"

请求注入

COOKIE

- cookie

POST

- data

HTTP

- 记得加*

-r x.txt

权限注入

文件操作

- file-read
- file-write
- file-dest

命令执行

- os-shell
- os-cmd

注册表读取

tamper插件使用

- <https://www.cnblogs.com/bmjoker/p/9326258.html>

其他注入

二次注入

原理

- 插入payload到数据库
- 数据库取出后拼接执行

功能点

- 会员中心-个人信息
- 会员中心-新建文章
- 后台系统

特征

- 大部分工具扫描不到

堆叠注入

支持数据库

- MYSQL
- MSSQL
- PSOTGRESQL

原理

- 多条语句执行

DNS带外

平台

- <http://www.dnslog.cn>
- <http://admin.dnslog.link>
- <http://ceye.io>

走向

- DNS协议

价值

- 注入鸡肋
- 其他漏洞

应用

- 无法回显
- 数据通讯 (出网出口问题)

代码块

验证

- 前端
- 后端

检验

内容

- 文件头
- 完整性
- 二次渲染
- 特征代码

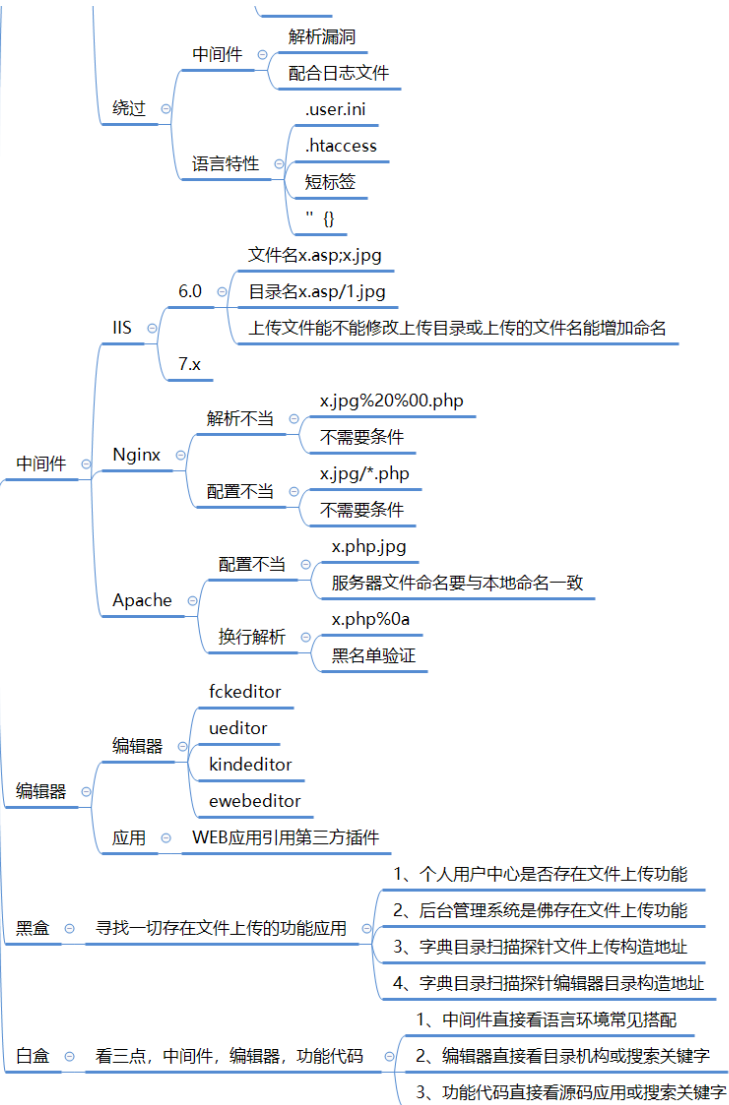
后缀

- 黑名单
- 白名单

MIME

通用安全漏洞

2 文件上传



原理

- 1.接收输入
- 2.接收后输出

将接收的数据进行页面显示，数据一旦是js代码，将被调用执行js，实现xss攻击

危害

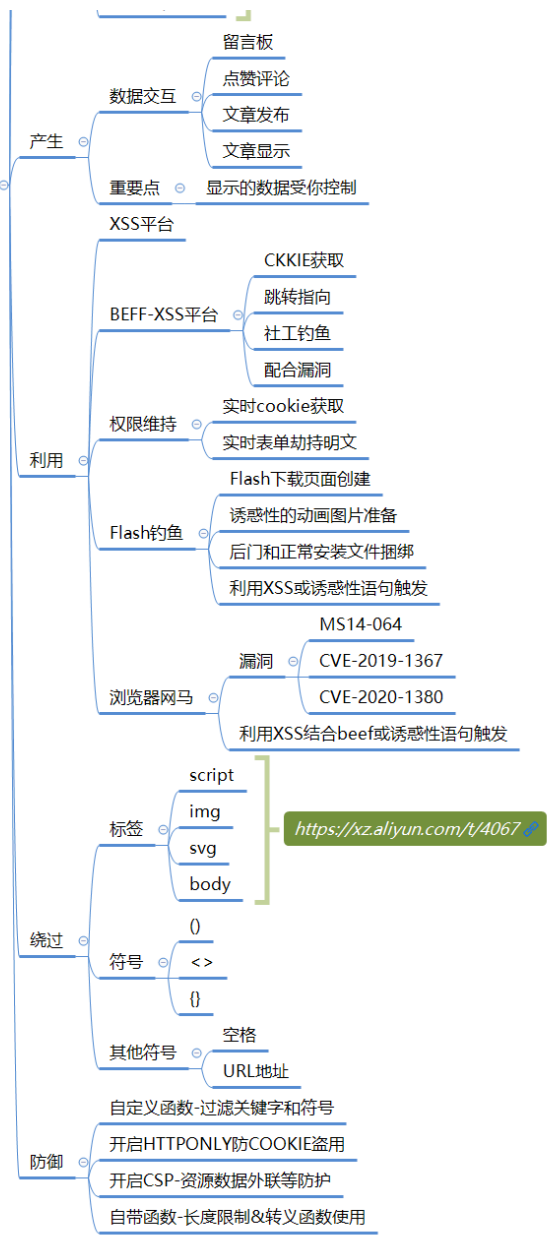
- 钓鱼
- 引流
- 挂马
- 权限丢失
- 劫持浏览器

分类

- 反射型（非持久型）
 - 一次性构造利用
- 存储型（持久型）
 - 攻击代码存储在数据库的持久型XSS攻击
- DOM 型
 - 接收输出均在JS实现，后期构造在HTML代码中
- mXSS(突变型 XSS)
 - 过滤后通过分享、转载、预览等激活成功
- UXSS（通用型 xss）
 - 浏览器的漏洞导致
- Flash XSS
 - SWF与JS代码的调用
 - 黑盒
 - SWF下载后反编译审计
 - 爬虫，目录扫描探针到
 - 白盒
 - SWF下载后反编译审计
 - 反编译工具
 - JPEXS Free Flash Decompiler
- PDFXSS
 - 1、创建 PDF，加入动作 JS
 - 2、通过文件上传获取直链
 - 3、直链地址访问后被触发
- UTF-7 XSS
- MHTML XSS
- CSS XSS
- VBScript XSS

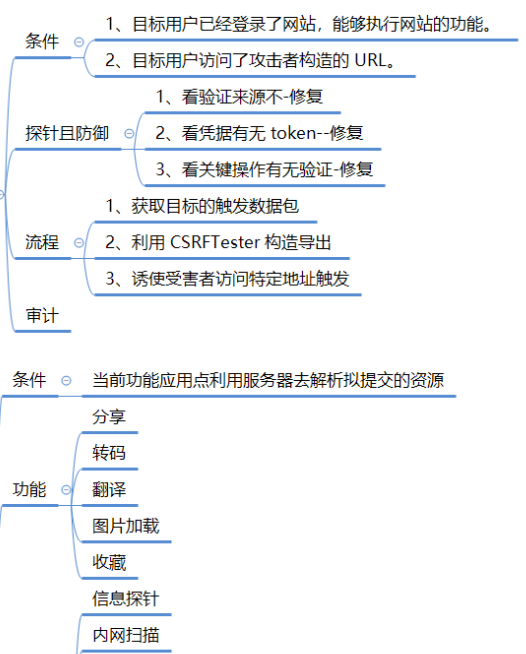
利用条件过时，大部分都是低版本IE

3 XSS跨站



<https://xz.aliyun.com/t/4067>

4 CSRF



	PHP	Java	curl	Perl	ASP.NET
http	✓	✓	✓	✓	✓
https	✓	✓	✓	✓	✓
grapher	—with curlwrappers	before JDK 1.7	before 7.68.0 不支 libcurl	✓	before version 3

5 SSRF

流程

协议玩法

[illegible]

探针且防御 SSRF常见安全修复防御方案:

- 1、禁用跳转
- 2、禁用不需要的协议
- 3、固定或限制资源地址
- 4、错误信息统一信息处理

审计

SSRF白盒可能出现的地方

- 1、功能点抓包指向代码块审计
- 2、功能点函数定位代码块审计

SSRF黑盒可能出现的地方

- 1.社交分享功能
- 2.转码服务
- 3.在线翻译
- 4.图片加载/下载
- 5.图片/文章收藏功能
- 6.云服务厂商
- 7.网站采集，网站抓取的地方
- 8.数据库内置功能
- 9.邮件系统
- 10.编码处理/属性信息处理，文件处理
- 11.未公开的api实现以及其他扩展调用URL的功能
- 12.从远程服务器请求资源

6 XXE&XML

前置

缘由：传输和存储数据

危害：文件读取，端口探针等

探针

Content-Type

黑盒 数据格式

svg&exc

1、可通过应用项

白盒

- 1、可通过应用功能追踪代码定位审计
- 2、可通过脚本特定函数搜索定位审计
- 3、可通过伪协议玩法绕过相关修复等

利用

file读取文件

http帶外访问

file读取文件-先读取

http带外访问-加载实体

dtd实体带外访问-将数据参数发送

接收文件接收数据处理

伪协议玩法 ① 见笔记图。后期文件包含会讲

修复

禁用dtd实体引用

过滤关键词:<!DOCTYPE和<!ENTITY, 或者SYSTEM和PUBLIC

分类

LFI本地包含

RFI远程包含

语言代码段

```
<!--#include file="1.asp" -->
```

```
<!--#include file="top.aspx" -->
```

```
<c:import url="http://thief.one/1.jsp">
```

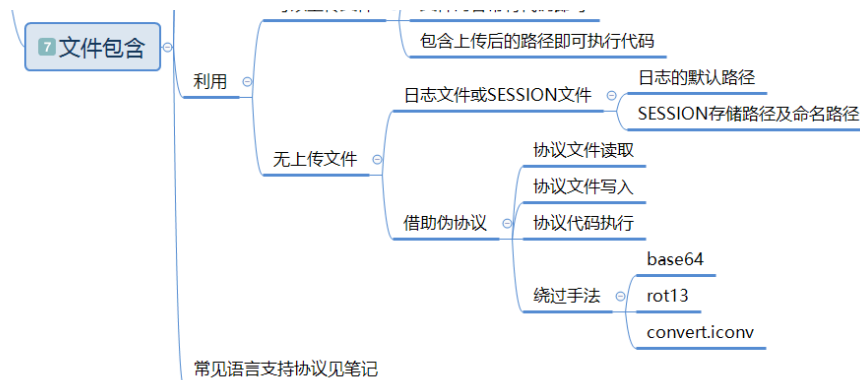
```
<jsp:include page="head.jsp"/>
```

```
<%@ include file="head.jsp"%>
```

```
<?php Include('test.php')?>
```

上传任意后缀文件

可以上件文件 文件由空带右件码即可



1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库漏洞下载
- 3、ASP-IIS-CVE&短文件&解析&写入

- 1、PHP-MYSQL-SQL注入-常规查询
- 2、PHP-MYSQL-SQL注入-跨库查询
- 3、PHP-MYSQL-SQL注入-文件读写

- 1、PHP-MYSQL-SQL注入-数据请求类型
- 2、PHP-MYSQL-SQL注入-数据请求方法
- 3、PHP-MYSQL-SQL注入-数据请求格式

- 1、PHP-MYSQL-SQL注入-方式增删改查
- 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
- 3、PHP-MYSQL-SQL注入-数据回显&报错处理

- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
- 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
- 3、PHP-MYSQL-SQL注入-带外注入&利用条件

- 1、注入工具-SQLMAP-常规猜解&字典配置
- 2、注入工具-SQLMAP-权限操作&文件命令
- 3、注入工具-SQLMAP-Tamper&使用&开发
- 4、注入工具-SQLMAP-调试指纹&风险等级

-
- 1、PHP-原生态-文件上传-检测后缀&黑白名单
 - 2、PHP-原生态-文件上传-检测信息&类型内容
 - 3、PHP-原生态-文件上传-函数缺陷&逻辑缺陷
 - 4、PHP-原生态-文件上传-版本缺陷&配置缺陷
-

- 1、PHP-中间件-文件上传-CVE&配置解析
 - 2、PHP-编辑器-文件上传-第三方引用安全
 - 3、PHP-CMS源码-文件上传-已知识别到利用
-

- 1、文件上传-安全解析方案-目录权限&解码还原
 - 2、文件上传-安全存储方案-分站存储&OSS对象
-

- 1、文件包含-原理&分类&危害-LFI&RFI
 - 2、文件包含-利用-黑白盒&无文件&伪协议
-

- 1、文件安全-前后台功能点-下载&读取&删除
 - 2、目录安全-前后台功能点-目录遍历&目录穿越
-

2.演示案例

2.1 文件安全-下载&删除-案例黑白盒



- 1 1、下载=读取
- 2 常规下载URL: <http://www.xiaodi8.com/upload/123.pdf>
- 3 可能存在安全URL: <http://www.xiaodi8.com/xx.xx?file=123.pdf>
- 4 利用: 常规下载敏感文件(数据库配置, 中间件配置, 系统密钥等文件信息)
- 5 2、文件删除(常出现后台中)
- 6 可能存在安全问题: 前台或后台有删除功能应用
- 7 利用: 常规删除重装锁定配合程序重装或高危操作

2.2 目录安全-遍历&穿越-案例黑白盒



- 1 1、目录遍历
- 2 目录权限控制不当, 通过遍历获取到有价值的信息文件去利用
- 3 2、目录穿越(常出现后台中)
- 4 目录权限控制不当, 通过控制查看目录路径穿越到其他目录或判断获取价值文件再利用

2.3 黑白盒分析



- 1 #黑盒分析:
- 2 1、功能点
- 3 文件上传, 文件下载, 文件删除, 文件管理等地方
- 4 2、URL特征
- 5 文件名:
- 6 download, down, readfile, read, del, dir, path, src, Lang等
- 7 参数名:
- 8 file、path、data、filepath、readfile、data、url、realpath等



- 1 #白盒分析:
- 2 上传类函数, 删除类函数, 下载类函数, 目录操作函数, 读取查看函数等